COMPOSIO · APM (TOOLKITS) · TAKE-HOME ASSIGNMENT

# OAuth App Guides

Verified, shareable guides for creating and getting approval for the OAuth app behind every user connection, plus a live agent that researches any app on demand.

**Yashvi Bansal**
Submitted 22 October 2026

LIVE APP

**oauth-guides-web.vercel.app**

Try a curated guide, or type any app to generate one live.

SOURCE CODE

**github.com/yb0203/oauth-app-guides**

The README is the full assessment document.

VERIFICATION REPORT

**docs/VERIFICATION.md**

What we checked, corrected and couldn't verify.

## AT A GLANCE

**5 + any**
Curated guides across all 4 difficulty tiers, plus live generation for any app

**3 / 3**
Difficulty tiers correct against our researched answer key

**~1 min**
To research and write a new guide (66 s on average in production)

**$0**
Spent: free models only, about 33k tokens per guide

OUR UNDERSTANDING

# How OAuth apps, Composio and user connections fit together

OAuth lets a user grant an app limited, revocable access without sharing their password. But before any user can click "Allow", the developer needs an approved OAuth app at the provider.

1 · PROVIDER OAUTH APP

### The gate

The developer's client registration at Google, Xero or Shopify: client ID and secret, redirect URI, scopes, consent screen. **Often needs the provider's approval.**

→

2 · COMPOSIO AUTH CONFIG

### The integration

Which OAuth app and scopes to use for a toolkit. Composio's own managed app (123 toolkits) or the developer's own (required for 211).

→

3 · CONNECTED ACCOUNTS

### The users

One per end user, holding that user's tokens. One OAuth app serves thousands of them, so if layer 1 isn't approved, nobody can connect.

APPROVAL VARIES ENORMOUSLY BY PROVIDER

**Instant**
GitHub, Notion
**Minutes**

**Verify to scale**
Xero, Microsoft
**Days, or a plan upgrade**

**Review required**
Gmail, Shopify, Slack, HubSpot
**Days to weeks**

**Partner only**
Spotify
**Months, or not at all**

### Scopes are the biggest lever

The same app can be easy or hard depending on the permissions requested. For Gmail, internal-only apps need no review, sending email is a sensitive scope (a review lasting days), and reading email is a restricted scope (review plus a paid yearly security assessment). A good guide shows what each permission costs.

### Gatekeepers on both sides

Passing the provider's review isn't the end. Customers' own admins can still block an app: Microsoft tenants often need admin consent, GitHub organizations restrict OAuth apps by default, and Slack workspaces can require approved apps. Guides cover both sides.

THE PROBLEM

# Every user connection depends on an OAuth app someone has to get approved

When an AI agent connects to a user's Gmail, Xero or Shopify, it does so through a provider OAuth app: a client registration the developer creates at the provider.

### Where developers get stuck

Composio supplies a managed app for 123 toolkits. For the other 211, and whenever a developer wants their own branding, rate limits or scopes, they must register their own app and often get it approved.

Setup can take five minutes (GitHub) or weeks with a paid security audit (reading Gmail). Sometimes only established companies are accepted (Spotify). Nobody can tell in advance which it'll be.

### Why this isn't "ask a chatbot"

Asked from memory, a model was wrong on several of these points: Spotify's user cap, GitHub's token default, which tier each app falls in. Providers changed their rules several times in 2026, and their own docs sometimes contradict each other.

**So the product is a research-and-verification process. The guide is its output.**

EVERY GUIDE ANSWERS FOUR QUESTIONS

### How hard is it?

One of four tiers: Instant, Verify to scale, Review required, or Partner only, with confidence.

### How long will it take?

Your hands-on hours and the provider's waiting time, shown separately.

### What do I need?

Accounts, limits, review requirements, customer-side gates and gotchas.

### Who does what?

Which steps the agent can do, and exactly where you have to take over.

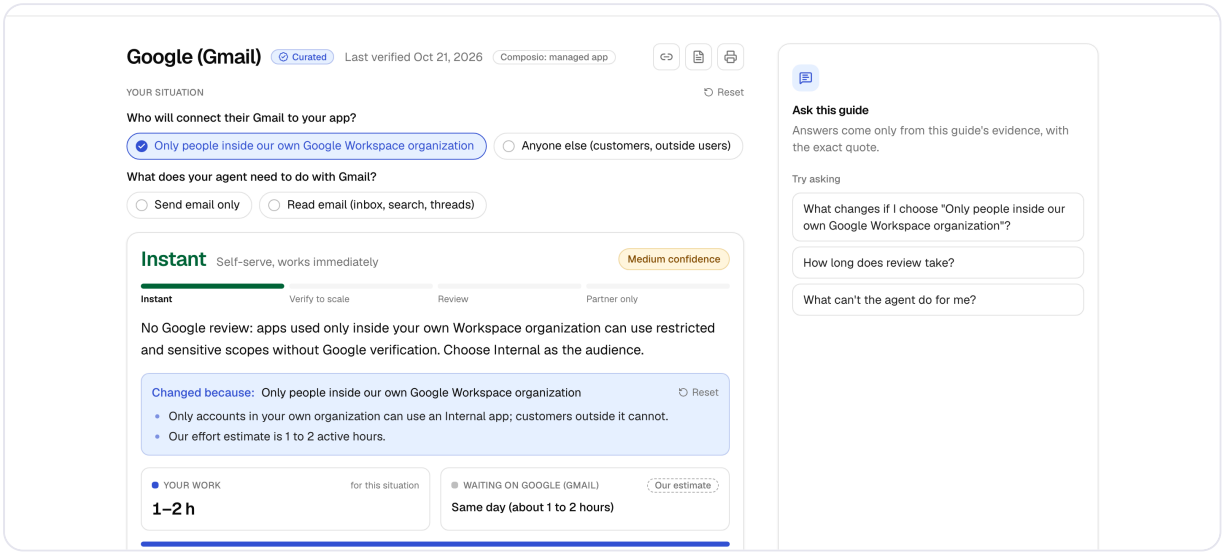
TRY IT IN FIVE MINUTES

# Three things to do in the live app

Everything below works at **oauth-guides-web.vercel.app**. No sign-in needed.

## 1 Watch the verdict change with your situation

Open the **Gmail guide**. Choose "Only people inside our own Google Workspace" and the verdict changes from **Review required** to **Instant**. Choose outside users who need to read email, and it becomes review plus a paid security assessment.




## 2 Ask the guide a question

Type "*Can I avoid Google review?*". The answer uses only this guide's verified evidence, with citations, and an **Apply** button sets your situation for you.

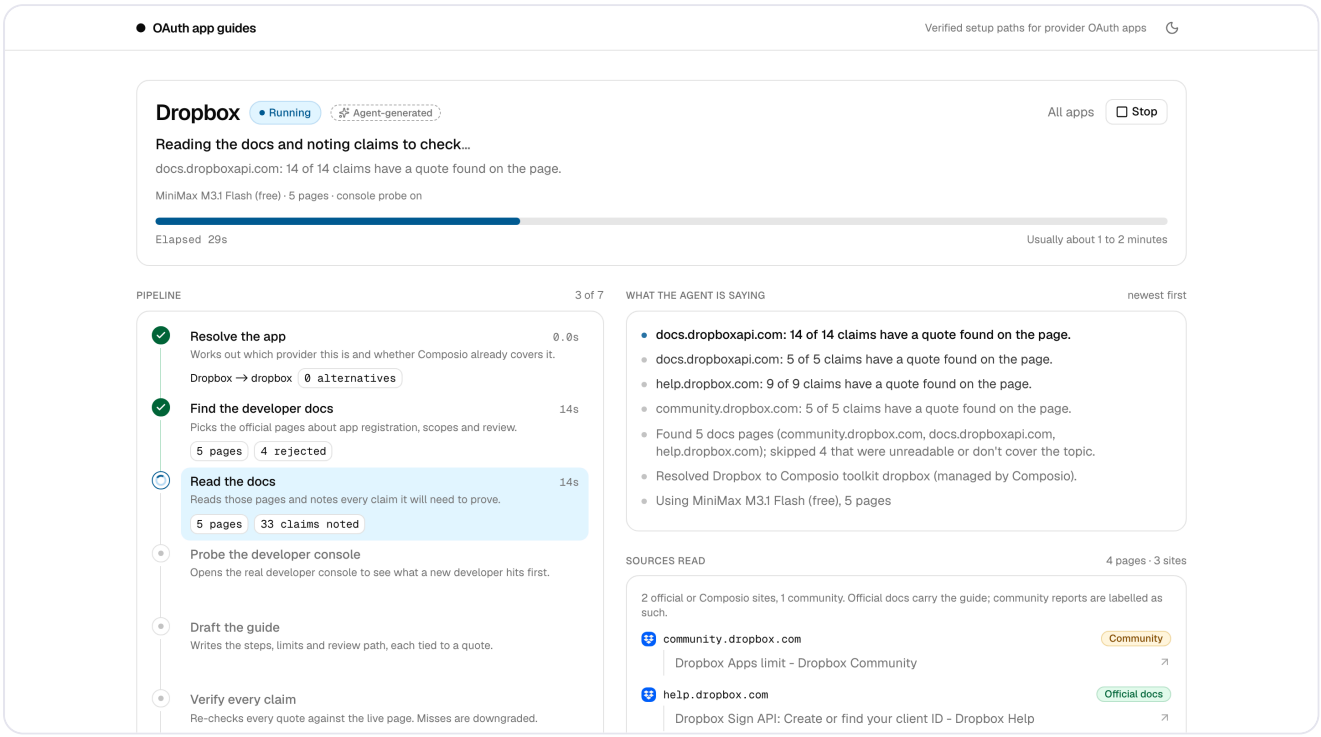
## 3 Generate a guide for an app we never researched

On the home page, type something like *Zoom*, *Dropbox* or *Asana*. You'll watch the agent find the provider's official docs, probe its developer console, write the guide and re-check every quote on the live pages. It takes about a minute.

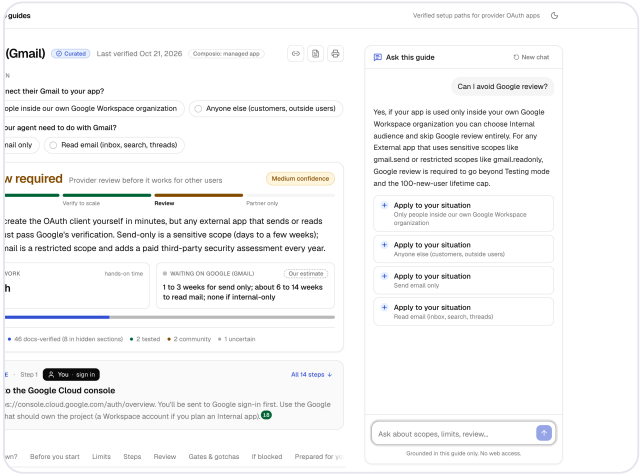
LIVE GENERATION

# Any app, researched in about a minute

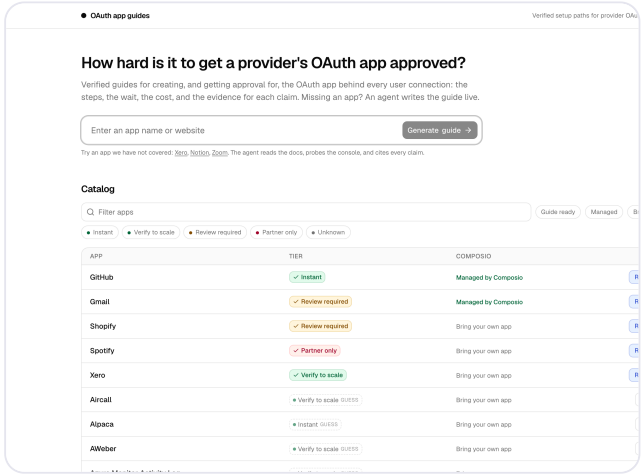
Progress streams as the agent works, and the result is a shareable guide with a permanent link and Markdown export.




Dropbox, which we never researched: pipeline stages, the agent's narration, and sources labeled official vs. community.




**Ask this guide:** answers come only from the guide's evidence, with Apply buttons.

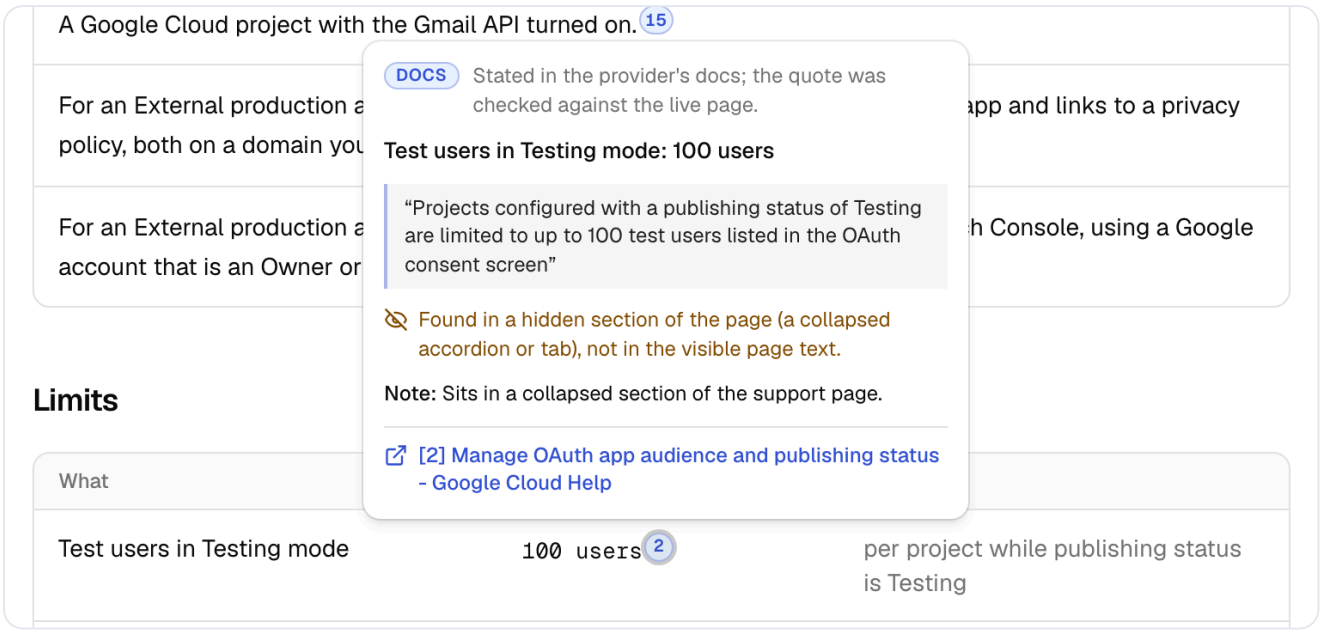



**Home and catalog:** 100 apps, with verified tiers where a guide exists.

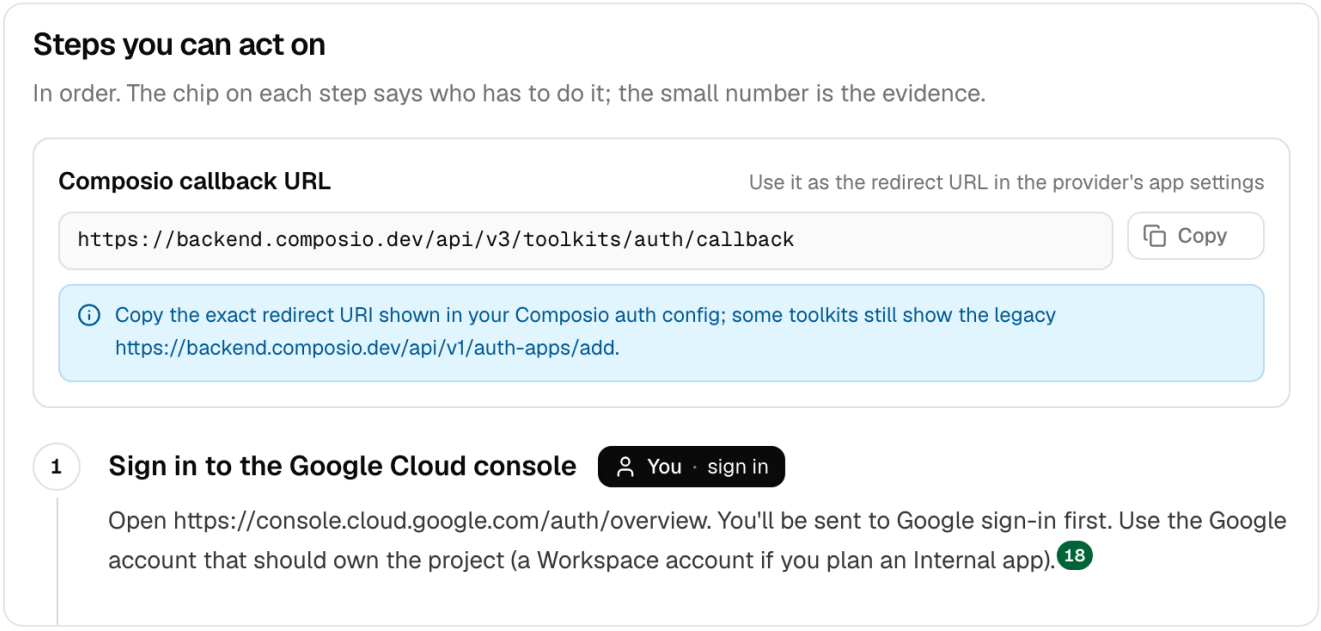
INSIDE A GUIDE

# Every fact shows its evidence, and every step shows who does it

Guides are built to act on: copy the exact values, know which steps are yours, and check any claim yourself.




**Citations:** hover any number to see the exact quote, whether it was found in a collapsed section of the page, and the source.




**Steps:** each says who does it and why (here, sign-in needs a real account), with copy buttons for the Composio callback and form values.

HOW IT WORKS

# Code verifies, models write

Each new app goes through a seven-stage pipeline. Everything that can be deterministic is plain code. Free LLMs do only two narrow jobs, and their output is checked against a schema.




Deterministic code  Free LLM via OpenRouter (narrow job, validated)

## FOUR EVIDENCE LABELS ON EVERY FACT

**TESTED**
Observed by our own tooling during the run, for example the console's sign-in wall.

**DOCS**
From the provider's official docs, with the exact quote re-found on the live page by code.

**COMMUNITY**
From third-party pages such as forums, blogs and integration vendors.

**UNCERTAIN**
Couldn't be verified. Shown openly, never quietly dropped.

**Why an agent can't simply create the OAuth app:** we tested it. On five providers, an agent with a real browser hit a sign-in page after one redirect every time. Everything past that (terms, Register, payment, review) needs a human. So the agent probes the console, does the research and drafts the materials (minimum scopes, justifications, consent-screen values), then hands off clearly.

THE BRIEF

# How this meets the brief

Each ask from the assignment, and where the answer is in the product or the repo.

| THE BRIEF ASKS | WHERE IT'S ANSWERED |
|---|---|
| **How easy or difficult it is to get the OAuth app ready** | A verdict with one of four tiers on a difficulty ladder, with confidence. It re-renders when you change "Your situation". |
| **Time and effort, including the approval wait** | "Your work" and "Waiting on the provider" shown separately; official vs. community-reported waits; cost. |
| **Requirements and nuances** | Before you start, limits (value, unit, scope), customer-side gates, gotchas, and conflicts where the provider's own docs disagree. |
| **What the agent can do, and where you take over** | Every step is marked You (with the reason), Agent or Either. "Prepared for you" holds drafted scopes and consent-screen values. |
| **Use agents to investigate and attempt setup** | The live pipeline runs for every new app. The setup-attempt experiment shaped the design. |
| **Be clear about what was tested, sourced or uncertain** | Four evidence labels, an evidence summary on every guide, citation cards, and conflicts shown openly. |
| **A library of guides; a few varied apps** | 5 curated guides covering all four tiers (GitHub, Xero, Gmail, Shopify, Spotify), plus a 100-app catalog. |
| **Generate a shareable guide live, for any app** | Streamed progress, then a permanent link and Markdown export. Tested on six apps we never researched. |
| **How to proceed when blocked** | "When you're blocked" (symptom → cause → fix), plus Ask this guide. |
| **Check a sample against sources; show corrections** | The verification report: research re-check, setup experiment, 247 live quote checks, 3 eval rounds, performance and cost. |

KEY DECISIONS

# Six choices that shaped the product

Each one came from something we tested or measured, not from assumptions.

### A verification process, not a prompt

Answers from memory were wrong or stale, so checking against live docs is the product.

### No pretend automation

All 5 consoles stopped at sign-in. The agent probes, researches and drafts, then hands off.

### Code verifies, models write

Search, probing, quote checks, labels and tier rules are deterministic. Models extract claims and write, and their output is validated.

### Bring-your-own first

Even for Composio-managed apps, guides cover registering your own app, and say when the managed one is enough.

### Free models only

Runtime uses free OpenRouter models behind a server allow-list. Claude Code was used only to build and test.

### Depth over breadth

5 varied apps done well, plus live generation for any app, instead of 100 shallow guides.

RESULTS

# What we measured on production

The live agent was scored against an answer key built from our verified research, then timed and costed.

| EVAL ROUND | TIER ACCURACY | FALLBACK DRAFTS | INFLATED LABELS | WHAT WE CHANGED AFTER |
|---|---|---|---|---|
| **Round 1** | 1.5 / 3 | 1 | **0** | Split and time-boxed the writer; added tier rules; restricted to official domains |
| **Round 2** | 2 / 3 | **0** | **0** | Instant tier when the docs show no review; filtered off-topic pages |
| **Round 3** | **3 / 3** | **0** | **0** | Final version |

## Performance and cost

- **~66 seconds** per guide on the default free model (8 runs, 51–96 s).
- **~33,000 tokens** per guide over about 7 model calls.
- **$0 actual spend**; the same tokens on a paid model would cost about $0.03 per guide.
- Most of the time goes to the model writing (about half) and reading pages.

## Verification

- **~75 research quotes** re-checked independently; 1 citation fixed.
- **247 live quote checks** on the curated guides.
- A quote-checker bug found and fixed: limits hidden in collapsed sections.
- **420 backend tests**, plus live-network tests.

## Known limitations

Anything behind a console login can't be verified and is marked UNCERTAIN. Links to generated guides can expire when the server restarts; curated guides are permanent. Production has no headless browser, so pages that render only with JavaScript may show as UNCERTAIN there. Free models sometimes miss numeric caps. Full detail is in the README and the verification report.

WHAT'S NEXT

# Where this could go next

Options we identified while building, roughly in order of value. Several are already partly designed or prototyped in the repo.

## For developers

### Inside Composio's dashboard

Show the guide right where a developer creates a bring-your-own auth config: callback prefilled, scopes suggested, a redirect-mismatch checker.

### Submission pack

One-click download of the drafted privacy-policy outline, scope justifications, consent-screen values and a demo-video script for the provider's review.

### Checklist and comparison

Track setup progress in the shareable link, and compare two or three apps side by side before committing to one.

## Better evidence

### Signed-in human pass

Capture real console forms once, using test accounts (for example with Browser Use), to turn "check on first sign-in" into tested steps.

### Continuous re-verification

Re-check every guide's quotes on a schedule, and flag guides whose source pages changed. Providers changed their rules several times in 2026.

### Real wait-time data

Let developers report how long their review actually took, replacing anecdotal community estimates.

## Platform and scale

### Permanent generated guides

Store generated guides durably (for example in Vercel Blob), so shared links never expire, and promote reviewed ones into the curated library.

### Grow to the full catalog

Generate guides for all 211 bring-your-own toolkits in the background, with human review before they're marked curated.

### Stronger runtime

A browser in production for JavaScript-rendered docs, Claude Managed Agents for long or scheduled runs (already prototyped), and an optional paid model for higher recall (about $0.03 a guide).

**Thanks for reviewing.** The fastest way in is the live app: **oauth-guides-web.vercel.app**. The README at **github.com/yb0203/oauth-app-guides** has setup instructions, every decision and the full verification report. Happy to walk through any of it live.